

Privacy Impact Assessment Report

COP-MODE Data Collection Campaign

Security and Privacy Lab – Assignment #2

University of Porto - Faculty of Science

Filipe Huang – up202406540
Diego Nóbrega – up202407575

Contents

1	Description of the System Setup	2
1.1	Overview and Purpose	2
1.2	PII Collected and Sensitivity	2
1.3	Actors and Information Flow	2
2	Initial Risk Assessment – Plain Setup	2
2.1	Likelihood and Severity Definitions	2
2.2	Identified Risks	3
2.3	Risk Matrix	3
3	Plan of Action – Corrective Measures	4
4	Risk Assessment for the Improved Setup	5
4.1	Residual Risk Levels and Justification	5
4.2	Improved Risk Matrix	6
4.3	Summary of Risk Evolution	6
4.4	Conclusion	6

1 Description of the System Setup

1.1 Overview and Purpose

COP-MODE is a research project focused on improving privacy on mobile devices through a smarter permission manager called CM-NPM [5]. The goal of the system is to better understand how users react to permission requests and to make these decisions more personalised and context-aware.

To study user behaviour, the project organises **one-week data collection campaigns**. During the campaign, participants receive a smartphone to use as their main device, while the CM-NPM application records contextual information whenever an app requests a permission.

1.2 PII Collected and Sensitivity

The CM-NPM app intercepts every permission request and immediately logs:

- Application name (package identifier) – **sensitive (marked **)**.
- User decision (allow/deny) and whether the request was expected.
- Location (GPS latitude, longitude, altitude).
- Device context (idle, in-call, foreground app, etc.).
- Calendar entries: identifier, location, start/end times – **sensitive**.
- Nearby devices (Bluetooth/Wi-Fi) and semantic location (e.g., “home” – user-supplied).

Pre-campaign, the team also collects the participant’s *email address* (main contact), *consent date*, *the list of installed apps* (to replicate their environment), and *connection type*.

1.3 Actors and Information Flow

- **PII principal/data subject**: the participant.
- **PII controller & processor**: the research institution (same entity).
- **Third parties**: partner researchers who receive only anonymised/aggregated data.

Data lifecycle: *collection (with consent) → structured recording → periodic transmission to the COP-MODE server → storage and analysis → limited disclosure (anonymised) → secure deletion* when the phone is returned or upon request.

2 Initial Risk Assessment – Plain Setup

The assessment assumes **no protection mechanisms**: *unencrypted HTTP, cleartext storage, server directly exposed to the internet, simple passwords, no pseudonymisation*. The CNIL PIA tool [2] was used to structure the evaluation, following methodologies described by Stallings [1] and the EU Smart Grid Task Force template [4].

2.1 Likelihood and Severity Definitions

We use a five-level scale based on established guidelines [1, 4]:

- **Likelihood**: probability that a threat action occurs and causes harm.
 - Very Low (1) – almost impossible.
 - Low (2) – unlikely, requires significant resources.

- Moderate (3) – possible, moderate attacker capability.
- High (4) – likely, weak protections.
- Very High (5) – almost certain, trivial to exploit.
- **Severity (Impact):** magnitude of damage to individuals.
 - Very Low (1) – negligible effect.
 - Low (2) – minor inconvenience.
 - Moderate (3) – noticeable harm, limited scale.
 - High (4) – serious harm, many affected.
 - Very High (5) – very severe, irreversible (identity theft, public exposure).

2.2 Identified Risks

Risk	Likelihood	Severity	Description
R1: Eavesdropping of communications	Very High (5)	Very High (5)	HTTP traffic can be sniffed; all data including email, apps, location exposed.
R2: Unauthorised server access	High (4)	Very High (5)	Server directly reachable, weak passwords; entire DB leaked.
R3: Data linkage (email in clear)	Moderate (3)	High (4)	Email stored with research data; any viewer instantly re-identifies participants.
R4: Sensitive app name leakage	High (4)	Very High (5)	Raw app names (health, dating, politics) stored without protection; intimate details exposed.
R5: Device loss/theft	High (4)	Very High (5)	Local cached data extracted; full behavioural profile compromised.
R6: Identity theft via calendar	High (4)	Very High (5)	Calendar reveals routines, locations, making identity theft/stalking easy.
R7: Data loss (hardware failure/attack)	High (4)	Very High (5)	No backups; permanent loss of research data.

Table 1: Initial risks (plain setup)

2.3 Risk Matrix

	VL(1)	L(2)	M(3)	H(4)	VH(5)
VH(5)				R2	R1,R4,R5,R6,R7
H(4)				R3	
M(3)					
L(2)					
VL(1)					

Figure 1: Initial risk matrix – all risks in unacceptable (red) zone.

Conclusion: Without controls, all risks are Very High – the project cannot proceed.

3 Plan of Action – Corrective Measures

We apply a defence-in-depth strategy using techniques from the course (cryptography, secure communications, access control, pseudonymisation). The following table covers the four specific risks required by the assignment, with detailed mitigations. Additional general measures are summarised afterwards.

Table 2: Mitigations for the four specified risks (required two-column table)

Risk	Mitigation
Data leak through eavesdropping of communications between smartphones and the project server.	• TLS 1.3 [6] with strong cipher suites enforced for all traffic. • Certificate pinning [7] in the app to prevent MITM attacks. • No cleartext fallback. • Regular certificate rotation and monitoring.
Data leak from unauthorised server/data access. Access must be limited; the server must not be directly exposed to the internet.	• Server behind firewall, only accessible via VPN [9] with multi-factor authentication [8]. • Role-Based Access Control (RBAC) [9, 10]: minimal raw-data viewers; others see anonymised extracts. • AES-256-GCM [11, 12] encryption at rest for sensitive fields. • Full logging and audit of all access.
Data at rest linkage. Email must be protected (not clear-text) but still linkable by the controller for deletion.	• Store email encrypted with AES-256-GCM [11, 12] in a separate, restricted mapping table. • Main research database holds only a random pseudonym. • Encryption key accessible only by the controller’s secure application. • Deletion request: controller decrypts mapping, locates pseudonym, cryptographically erases all records.

Sensitive information leakage – app names. Must allow equality checks without storing raw names.

- Replace each app name with **HMAC-SHA256** [13] using a secret key stored in a **Hardware Security Module (HSM)** [14].
- Hashing performed by an isolated microservice; key never leaves HSM.
- Equal inputs produce equal tokens – analysis possible, original names irrecoverable.
- Also apply **data minimisation** [15, 16] – do not collect app categories unnecessary for research.

Additional measures for all risks

- *Device security*: encrypt local data, enforce strong lock-screen authentication, enable remote wipe, minimise local retention.
- *Calendar protection*: minimise collected fields (no titles/attendees), use end-to-end encryption for remaining fields, coarsen location precision [15].
- *Backup & recovery*: automated daily encrypted backups to a separate site [9, 15], regular restoration tests, RAID storage.

4 Risk Assessment for the Improved Setup

After applying the corrective measures, the CNIL tool was used again to re-evaluate each risk.

4.1 Residual Risk Levels and Justification

Risk	New Likeli-hood	New Severity	Why the level dropped
R1: Eavesdropping	Low (2)	Moderate (3)	TLS 1.3 + pinning make interception infeasible. Severity still Moderate because underlying data remains sensitive.
R2: Unauthorised access	Low (2)	Low (2)	Firewall+VPN+MFA block entry; encryption at rest renders stolen data useless.
R3: Data linkage	Very Low (1)	Low (2)	Email encrypted and separated; linkage requires breaking both DB and HSM – practically impossible.
R4: App names	Low (2)	Low (2)	Tokens reveal nothing without HSM key; original names never stored.
R5: Device loss/theft	Low (2)	Low (2)	Encryption + strong authentication + remote wipe; data promptly cleared from device.

R6: Identity theft	Low (2)	Moderate (3)	Calendar minimised & encrypted. Severity still Moderate because location patterns are sensitive.
R7: Data loss	Very Low (1)	Low (2)	Encrypted daily backups + RAID; loss extremely unlikely.

Table 3: Residual risk after corrective measures

4.2 Improved Risk Matrix

	VL(1)	L(2)	M(3)	H(4)	VH(5)
VH(5)					
H(4)					
M(3)		R1,R6			
L(2)	R3,R7	R2,R4,R5			
VL(1)					

Figure 2: Residual risk matrix – all risks in acceptable (green/orange) zone.

4.3 Summary of Risk Evolution

Risk	Initial Level	Residual Level
Eavesdropping	Very High	Moderate
Unauthorised access	Very High	Low
Data linkage (email)	High	Very Low
App name leakage	Very High	Low
Device loss/theft	Very High	Low
Identity theft (calendar)	Very High	Moderate
Data disappearance	Very High	Low

Table 4: Comparison of risk levels

4.4 Conclusion

The plain setup exposed participants to intolerably high privacy risks. Through layered security and privacy controls – encryption (TLS [6], AES-256 [11], HMAC [13]), strict access control [9, 8, 10], pseudonymisation, tokenisation, and robust backups [9, 15] – every risk was reduced to **Moderate or Low**. The residual risk is acceptable under GDPR [15] and ethical standards. The PIA will be reviewed before each new campaign and whenever system or threat changes occur.

References

- [1] W. Stallings, *Information Privacy Engineering and Privacy by Design*, Pearson Addison-Wesley, 2020 (Chapter 11 – PIA Primer, provided on Moodle).
- [2] CNIL (Commission Nationale de l’Informatique et des Libertés), *The Open Source PIA Software Helps to Carry out Data Protection Impact Assessment*, <https://www.cnil.fr/en/open-source-pia-software-helps-carry-out-data-protection-impact-assessment> (Tutorial video: <https://www.youtube.com/watch?v=5J3h9zIFVDo>).
- [3] Statistics New Zealand, *Privacy Impact Assessment for the Integrated Data Infrastructure*, 2012, <https://www.stats.govt.nz>.
- [4] E.U. Smart Grid Task Force, *Data Protection Impact Assessment Template for Smart Grid and Smart Metering Systems*, September 2018, <https://energy.ec.europa.eu>.
- [5] COP-MODE Project Website, <https://cop-mode.dei.uc.pt>.
- [6] IETF, *RFC 8446 – The Transport Layer Security (TLS) Protocol Version 1.3*, August 2018, <https://datatracker.ietf.org/doc/html/rfc8446>.
- [7] OWASP Cheat Sheet Series, *Certificate Pinning*, https://cheatsheetseries.owasp.org/cheatsheets/Pinning_Cheat_Sheet.html.
- [8] NIST, *SP 800-63B-4 – Digital Identity Guidelines: Authentication and Lifecycle Management*, <https://pages.nist.gov/800-63-4/sp800-63b.html>.
- [9] NIST, *SP 800-53 Rev. 5 – Security and Privacy Controls for Information Systems and Organizations*, <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>.
- [10] ISO, *ISO/IEC 29146:2016 – Information technology – Security techniques – A framework for access management*, <https://www.iso.org/standard/63469.html>.
- [11] NIST, *FIPS 197 – Advanced Encryption Standard (AES)*, November 2001, <https://csrc.nist.gov/publications/detail/fips/197/final>.
- [12] NIST, *SP 800-38D – Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM)*, November 2007, <https://csrc.nist.gov/publications/detail/sp/800-38d/final>.
- [13] NIST, *FIPS 198-1 – The Keyed-Hash Message Authentication Code (HMAC)*, July 2008, <https://csrc.nist.gov/publications/detail/fips/198/1/final>.
- [14] NIST, *FIPS 140-3 – Security Requirements for Cryptographic Modules*, March 2019, <https://csrc.nist.gov/projects/cryptographic-module-validation-program>.
- [15] European Union, *Regulation (EU) 2016/679 (General Data Protection Regulation)*, Articles 5(1)(c), 25, and 32, <https://eur-lex.europa.eu/eli/reg/2016/679/oj>.
- [16] CNIL, *Practical Sheet n°7 – Minimize the Data Collection*, <https://www.cnil.fr/en/data-minimisation-sheet>.

Documentation of AI Use

Artificial Intelligence (AI) was used to assist in structuring the report, phrasing technical mitigations, and formatting *LaTeX tables*. All the contents were reviewed and validated by the group members, who take full responsibility for the analysis and conclusions.